
MEDICARE CONNECT (PTY) Ltd

RISK ASSESSMENT METHODOLOGY

Classification	: Internal
Version	: 1.0
Date	: June 2025
Author	: PV.Mohlala GRC Analyst
Aligned to	: ISO 27005:2022 / ISO 27001:2022

1. PURPOSE

This document defines how MediCare Connect identifies, analyses, evaluates and treats information security risks. A consistent methodology ensures risks are scored the same way by every assessor, allowing management to compare risks objectively and allocate budget where it reduces the most harm

2. SCOPE

This methodology applies to all information assets, systems, processes and third parties within the ISMS scope defined in the Compliance Program Overview v1.0.

3. RISK ASSESSMENT PROCESS

STEP 1: ASSET IDENTIFICATION

Identify the information asset at risk (Reference: Asset Register v1.0)

STEP 2: THREAT IDENTIFICATION

Identify what could cause harm to the asset

STEP 3: VULNERABILITY IDENTIFICATION

Identify the weakness the threat exploits

STEP 4: IMPACT ANALYSIS

Determine consequence if the risk occurs

STEP 5: LIKELIHOOD ANALYSIS

Determine probability of occurrence

STEP 6: RISK SCORING

Calculate: Likelihood x Impact = Risk Score

STEP 7: RISK EVALUATION

Compare score against risk acceptance criteria

STEP 8: RISK TREATMENT

Select treatment option and assign owner

STEP 9: RESIDUAL RISK

Re-score risk after controls applied

STEP 10: MONITOR AND REVIEW

Quarterly review of all risks

4.LIKELIHOOD SCALE

Score	Rating	Definition
1	- Rare	- Unlikely in 5 years
2	- Unlikely	- Possible in 3 years
3	- Possible	- Likely within 1 year
4	- Likely	- Expected quarterly
5	- Almost - Certain	- Occurring now or - expected monthly

5.IMPACT SCALE

Score	Rating	Business Consequence
1	Minor	< R50 000 loss No patient data affected No regulatory interest
2	Moderate	R50 000 - R250 000 Internal data exposed Minor service disruption
3	Major	R250 000 - R1 million Limited patient data POPIA notification req
4	Severe	R1 million - R5 million Mass patient data breach Regulator investigation Media coverage
5	Critical	> R5 million Full database compromise Max POPIA fine R10m Director liability Patient safety at risk Business closure risk

6. RISK SCORING MATRIX

Risk score = Likelihood x Impact

Range : 1 -25

		IMPACT →					
LIKELIHOOD ↓		1	2	3	4	5	
	5	5	10	15	20	25	
	4	4	8	12	16	20	
	3	3	6	9	12	15	
	2	2	4	6	8	10	
	1	1	2	3	4	5	

7. RISK LEVEL CLASSIFICATION

Score	Level	Required Response
20 - 25	CRITICAL	Immediate action. CEO notified. Treat within 30 days.
12 - 19	HIGH	Treat within 90 days. Management approval required for spend.
6 - 11	MEDIUM	Treat within 6 months. Monitor quarterly.
1 - 5	LOW	Accept and monitor. Review annually.

8. RISK ACCEPTANCE CRITERIA

MediCare Connect will NOT accept any risk scoring 12 or above (HIGH or CRITICAL) without a documented treatment plan.

Any risk involving patient special personal information under POPIA must be reduced to a residual score of 9 or below.

Risk acceptance authority:

- Score 1-5 : IT Manager
- Score 6-11 : Information Officer
- Score 12-19 : Executive Committee
- Score 20-25 : CEO and Board only

9. RISK TREATMENT OPTIONS

Mitigate (Reduce)

Apply controls to lower likelihood or impact. Default option for most risks.

Transfer (Share)

Move risk to third party via insurance or contractual agreement.

Avoid (Terminate)

Stop the activity that creates the risk.

Accept (Tolerate)

Formally accept the risk with documented sign-off from the appropriate authority.

10. REVIEW FREQUENCY

Critical risks : Monthly

High risks : Quarterly

Medium risks : Every 6 months

Low risks : Annually

Full register review : Annually or after any significant incident or business change.

Document Control

Prepared by : Patrick Mohlala, GRC Analyst

Approved by : Information Officer

Version : 1.0

Next Review : June 2026
